



Executive Summary

OVERALL HEALTH

⚠ Action Required

Yellow

Functional but high operational complexity

Strong Points

- High automation velocity (180+ scripts)
- Strong gate culture
- Recent security hardening
- Modern auth evolution

Critical Issues

- **Monolithic backend** (1,196 lines)
- **Skipped webhook HMAC**
- **In-memory OAuth state**
- **Extreme docs sprawl** (1,023 files)

Top Priority

Close webhook & OAuth gaps

Highest risk × impact items (score 36)

Est. Phase 0 effort

3–6 weeks

Key Risks (if unaddressed)

Webhook forgery risk

HMAC verification skipped when secrets are unset (common in staging/prod).

OAuth / Login instability

In-memory state breaks on multi-instance Cloud Run deployments.

Top Technical Debt

Prioritized by (Impact + Risk) × (6 - Effort)

ITEM	SCORE	IMPACT	RISK	EFFORT	OWNER
In-memory OAuth state	36	4	5	2	Backend

ITEM	SCORE	IMPACT	RISK	EFFORT	OWNER
Webhook HMAC skipped when secret absent	36	4	5	2	Security
Monolithic server/index.js (1,196 lines)	30	5	5	4	Backend lead
Brittle test execution (giant && chain)	24	3	4	2	CI/Test owner
Documentation fragmentation (1,023 .md files)	21	3	4	3	Docs owner



Security Snapshot

Critical Gaps

- Webhook HMAC verification skipped when secrets unset
- OAuth state stored in-memory (multi-instance failure)
- PANELIN_RELAX_DEV_AUTH flag too permissive

OWASP Top 10 Highlights

A02 Cryptographic: At risk
A04 Insecure Design: At risk

A07 Auth Failures: At risk
A06 Vulnerable Components: Moderate (3)



Phase 0 — Critical (Do Immediately)

1. Make webhook secrets mandatory in production

3–5 days

Remove silent skip in whatsappSignature.js & mlSignature.js. Fail hard or return 401 when secrets missing.

Owner: Backend + Security

2. Persist OAuth state (replace in-memory Map)

1 week

Move oauthStates from server/index.js to Supabase (reuse tasks.oauth_state pattern).

Owner: Backend

3. Fix test runner + add coverage baseline

3–5 days

Replace giant && chain. Add coverage collection for pricing, auth, and signature paths.

Owner: CI owner

Phase 1 — Next 3 Months (Key Items)

- Decompose server/index.js monolith
- Archive "docs 2/" + create canonical docs INDEX
- Enforce relax-dev-auth strictly
- Upgrade react-router (fix open redirect)
- Add HMAC enforcement tests for ML & WA
- Finish GCP Secret Manager / IAM Phase 1

RECOMMENDATION

**The system delivers real value and moves fast.
The priority now is making that velocity sustainable.**

Focus on the 3 Phase 0 items immediately. Estimated payback: reliability + development speed within one quarter.